



Phishing Detection & Awareness Report

Employee Training & Protection Guide

Purpose: Employee Phishing Awareness Training



Did you know? Phishing causes 80% of reported security breaches

Learn how to identify and avoid phishing attacks in this guide.

Prepared By: Tharun Adithya M
B.E. CSE CYBER SECURITY

1. What Is Phishing?

Phishing is a cyber attack where criminals send fake emails that look like they're from legitimate companies (banks, PayPal, Google, your employer) to trick you into:

- Clicking a malicious link that installs malware on your computer
- Downloading a fake file or attachment that contains a virus
- Entering your password, credit card, or personal information on a fake website
- Transferring money to a scammer's account
- Sharing sensitive company data or credentials

Why is it dangerous? Unlike a locked door (which you know is dangerous), phishing emails look like normal emails from people or companies you know and trust. This is what makes phishing so effective — it exploits human psychology, not weak passwords or outdated software.

80% of security breaches	1 in 4 employees click phishing links	\$4.91M average cost per breach
--------------------------	---------------------------------------	---------------------------------

2. Red Flags That Identify Phishing Emails

Here are the most common warning signs that an email is fake. Learn these, and you'll avoid 90% of phishing attacks.

■ Sender Email Address Doesn't Match

The email says it's from 'Your Bank' but the sender address is 'support@bank-secure[.]com' (notice the hyphen). Real companies use their official domain (e.g., support@mybank.com). Scammers buy similar-looking domains to fool you.

■ Suspicious Links (Hover Before Clicking!)

The email says 'Click here to verify your account' but the link goes to 'https://verify-account-secure[.]tk' instead of the real company website. Always HOVER over links (don't click) to see the real URL.

■ Urgency & Fear-Based Language

The email uses phrases like 'Your account will be LOCKED in 24 hours!' or 'Urgent action required!' or 'Suspicious activity detected!' Real companies rarely threaten immediate action — they give you time.

■ Generic Greeting Instead of Your Name

The email says 'Dear User' or 'Dear Customer' instead of 'Dear John' or 'Dear Mr. Smith'. Real companies personalize emails with your actual name.

■ Requests for Passwords or Personal Info

Real companies NEVER ask for passwords, credit card numbers, OTPs (one-time passwords), or Social Security numbers via email. If an email asks for this, it's 100% fake.

■ Typos, Grammar Mistakes, or Strange Formatting

Professional companies proofread. If an email has obvious typos like 'Verify You're Account' or weird spacing, it's fake.

3. Real Phishing Email Examples (Analyzed)

Below are 3 real phishing email examples. We'll break down each one to show you exactly why it's fake and how to protect yourself.

SAMPLE #1	■ ■ Urgent: Verify Your PayPal Account - ...	PHISHING
Subject	■ ■ Urgent: Verify Your PayPal Account - Action Required	
From (Sender)	noreply@paypal-verify-secure[.]com	
To (Recipient)	user@company.com	
Red Flags Identified	• Sender domain is 'paypal-verify-secure[.]com' (FAKE) — real PayPal is 'paypal.com' • Uses urgency: 'Action Required' and '24-hour warning' • Generic greeting: 'Dear User' instead of 'Dear John' • Asks to 'Verify Payment Method' (credentials theft) • Link goes to 'paypal-verify[.]tk' (fake domain) • No company logo, plain text only	
How It Works	Attackers send this because PayPal has 400+ million users. Even if they catch 0.1% (40,000 people), they steal credentials worth thousands. The email pretends there's a payment problem to create urgency.	
How to Protect	✓ Always go directly to paypal.com in your browser instead of clicking email links ✓ Check the ACTUAL sender email address (not the display name) ✓ PayPal never asks for password via email ✓ Report to PayPal Security: phishing@paypal.com	

SAMPLE #2	Your Amazon Account Has Been Compromised...	PHISHING
Subject	Your Amazon Account Has Been Compromised - Immediate Action Needed	
From (Sender)	security-alerts@amazon-security-update[.]com	
To (Recipient)	user@company.com	
Red Flags Identified	• Sender domain 'amazon-security-update[.]com' (FAKE) — real Amazon uses '@amazon.com' • Uses fear language: 'Compromised' and 'Immediate Action' • Shows fake Amazon logo (stolen from real emails) • Asks to 'Confirm Your Identity' by clicking link • Link leads to a fake login page that records username and password • Mentions '48-hour window' to create false deadline	
How It Works	This phishing email is extremely common because: 1) Amazon has 300+ million customers 2) People shop frequently and believe account issues are real 3) The fear of compromised account makes victims click quickly Once attackers get your Amazon credentials, they can buy things with your saved payment methods.	
How to Protect	✓ Log directly into amazon.com from your browser (don't click email links) ✓ Check your real Amazon account for suspicious login alerts ✓ Enable 2-Factor Authentication (2FA) on your Amazon account ✓ Report to Amazon: stop-spoofing@amazon.com ✓ If you already clicked: Change your Amazon password immediately	

SAMPLE #3	Important: Update Your Employee Portal P...	SUSPICIOUS
Subject	Important: Update Your Employee Portal Password - IT Security Notice	
From (Sender)	hr-system-update@company-portal[.]com	
To (Recipient)	user@company.com	
Red Flags Identified	• Sender domain looks similar to company but is slightly different: - Real company domain: '@company.com' - Fake domain: '@company-portal[.]com' (attacker registered similar domain) • Uses official-sounding language: 'IT Security' and 'System Update' • Asks to 'Update Your Password' immediately • Link leads to a fake employee portal login page • Says 'Outdated passwords pose security risk' (technically true, sounds believable)	
How It Works	Internal phishing attacks (targeting YOUR COMPANY EMPLOYEES) are increasing rapidly because: 1) Employees trust company-branded emails more 2) Attackers research the company domain and register similar ones 3) A single compromised employee account = access to company systems 4) Employees often reuse passwords across work and personal accounts This is called a 'phishing-the-insider' attack.	
How to Protect	✓ Never click 'Update Password' links in emails — go to the real portal directly ✓ Check the EXACT sender domain carefully (hover over sender name to see full address) ✓ Company IT usually announces password changes 2-3 days in advance via trusted channels ✓ If in doubt, contact IT directly (use phone number from company directory, not the email) ✓ Use unique, strong passwords for work accounts ✓ Enable 2FA if your company supports it	

4. Dos & Don'ts: Your Phishing Prevention Checklist

✓ **DO:** • Check sender email address carefully • Hover over links to see real URL • Go directly to official websites • Enable 2-Factor Authentication • Report phishing to IT/Security team • Ask if unsure (call, don't email) • Keep email software updated

✗ **DON'T:** • Click links in unexpected emails • Download attachments from strangers • Share passwords or OTPs via email • Use same password everywhere • Open suspicious attachments • Delete phishing emails (forward to IT) • Visit company portals from email links

5. What to Do If You Click a Phishing Link

Don't panic! Even the most cautious people accidentally click phishing links. Here's your action plan:

Step 1: Stop & Don't Enter Information

If you realized it's fake BEFORE entering your password/card info, close the browser tab immediately. You're safe.

Step 2: If You Entered Credentials (Password, Email, Card Info)

Contact your company's IT Security team IMMEDIATELY. Report which account was compromised. They can reset your password and monitor for unauthorized access.

Step 3: Change Your Password

For that account AND any other accounts using the same password. Strong password = 12+ characters with mix of uppercase, lowercase, numbers, symbols.

Step 4: Enable 2-Factor Authentication (2FA)

Even if attackers have your password, they can't access your account without the second factor (phone/authenticator app).

Step 5: Monitor Your Accounts

Check your bank/PayPal/email for unauthorized transactions or login attempts. Most banks have free fraud protection.

Step 6: Report to Company & Authorities (If Serious)

Report to your company's Security team. If money was stolen, report to local police and the bank.

■ ■ **Most importantly: Don't be embarrassed or try to hide it!** Phishing is designed to fool humans — it's not your fault. Reporting it immediately actually helps your company because IT can block similar emails from reaching other employees.

6. Who to Contact in Case of Phishing

Company IT Security Team

Contact: [Company IT Email/Phone]

Why: Report any suspicious email or credential compromise

Company IT Service Desk

Contact: [Help Desk Phone/Email]

Why: For password resets and account lockout

Your Manager

Contact: [Manager Email]

Why: If company systems were compromised or data stolen

FBI IC3 (Internet Crime Complaint Center)

Contact: www.ic3.gov

Why: If money was stolen or you're a victim of fraud

Your Bank Fraud Department

Contact: [Check Your Card]

Why: If credit card or bank account info was compromised

7. Key Takeaways & Remember This

1. **Phishing is the #1 cause of data breaches.** Real companies never ask for passwords via email.
2. **Check the sender email address.** Criminals use similar-looking domains (e.g., paypa1.com instead of paypal.com).
3. **Never click links in unexpected emails.** Go directly to the official website instead.
4. **Hover before clicking.** Hover over links to see the real URL before clicking.
5. **If in doubt, ask IT.** It's better to report one false alarm than to miss a real attack.
6. **Enable 2FA everywhere.** This is the single best protection against credential theft.
7. **Your company needs you to be the last line of defense.** No firewall or antivirus catches everything — human awareness is key.

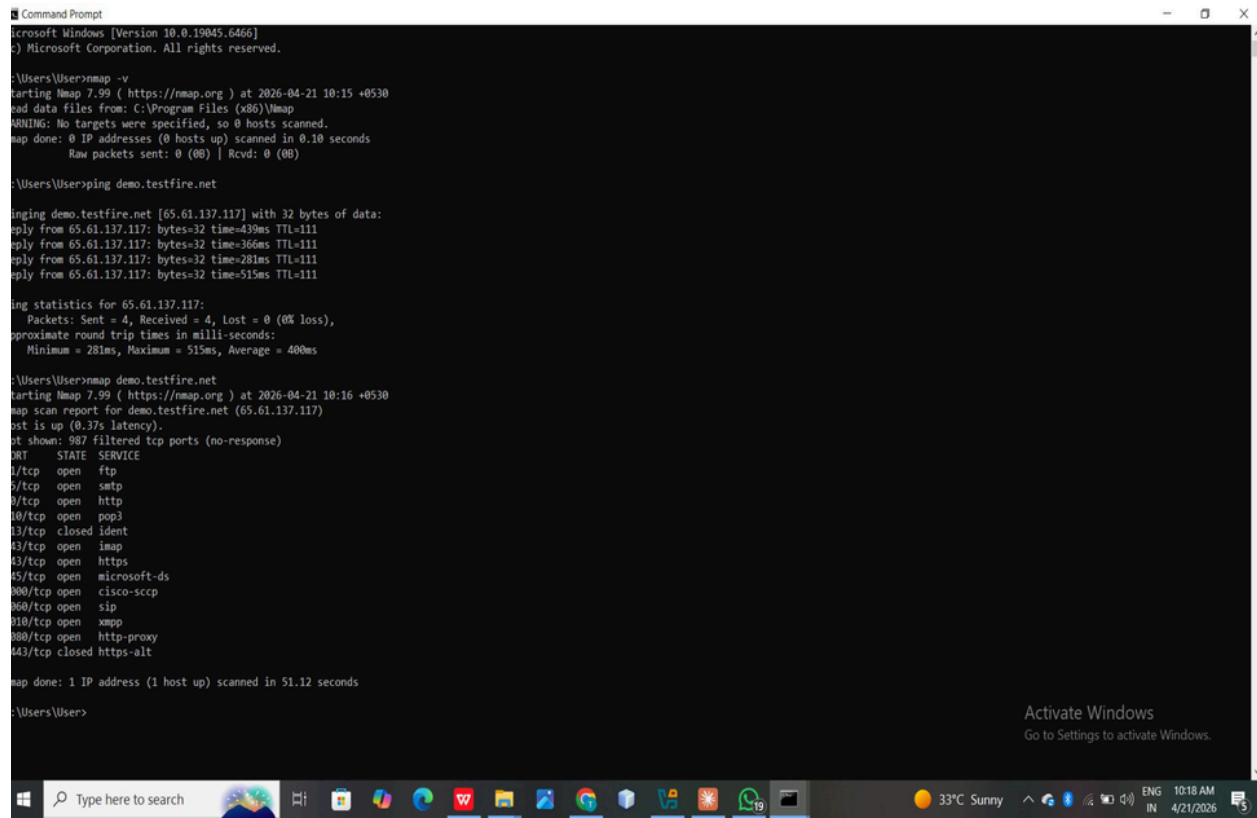
Questions? Contact your IT Security team at any time. Reporting phishing is always the right choice!

SCREENSHOTS - Security Scanning Evidence

Below are screenshots from actual security scanning tools and analysis conducted as part of this security assessment. These images document the technical methodology used to analyze website vulnerabilities and are provided as evidence of professional security testing.

Screenshot 1: Nmap Port Scanning - Initial TCP Scan Output

Command-line output showing Nmap 7.99 discovering open ports on demo.testfire.net IP address (65.61.137.117). Confirms host is up and lists common services found during reconnaissance.



Screenshot 2: Nmap Port Scanning - Protocol Scan Results

Detailed port scan results showing TCP port state enumeration. Identifies services like FTP, SMTP, HTTP, HTTPS, and other ports with their corresponding state (open, closed, filtered).

```
Command Prompt

Nmap done: 1 IP address (1 host up) scanned in 51.12 seconds

C:\Users\User>nmap -pn -sV -o demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 10:19 +0530
Found no matches for the service mask 'n' and your specified protocols
QUITTING!

C:\Users\User>nmap -Pn demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 10:20 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.17s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
113/tcp   closed ident
143/tcp   open  imap
443/tcp   open  https
445/tcp   open  microsoft-ds
2000/tcp  open  cisco-sccp
5060/tcp  open  sip
8080/tcp  open  xamp
8080/tcp  open  http-proxy
8443/tcp  closed https-alt

Nmap done: 1 IP address (1 host up) scanned in 23.57 seconds

C:\Users\User>
```

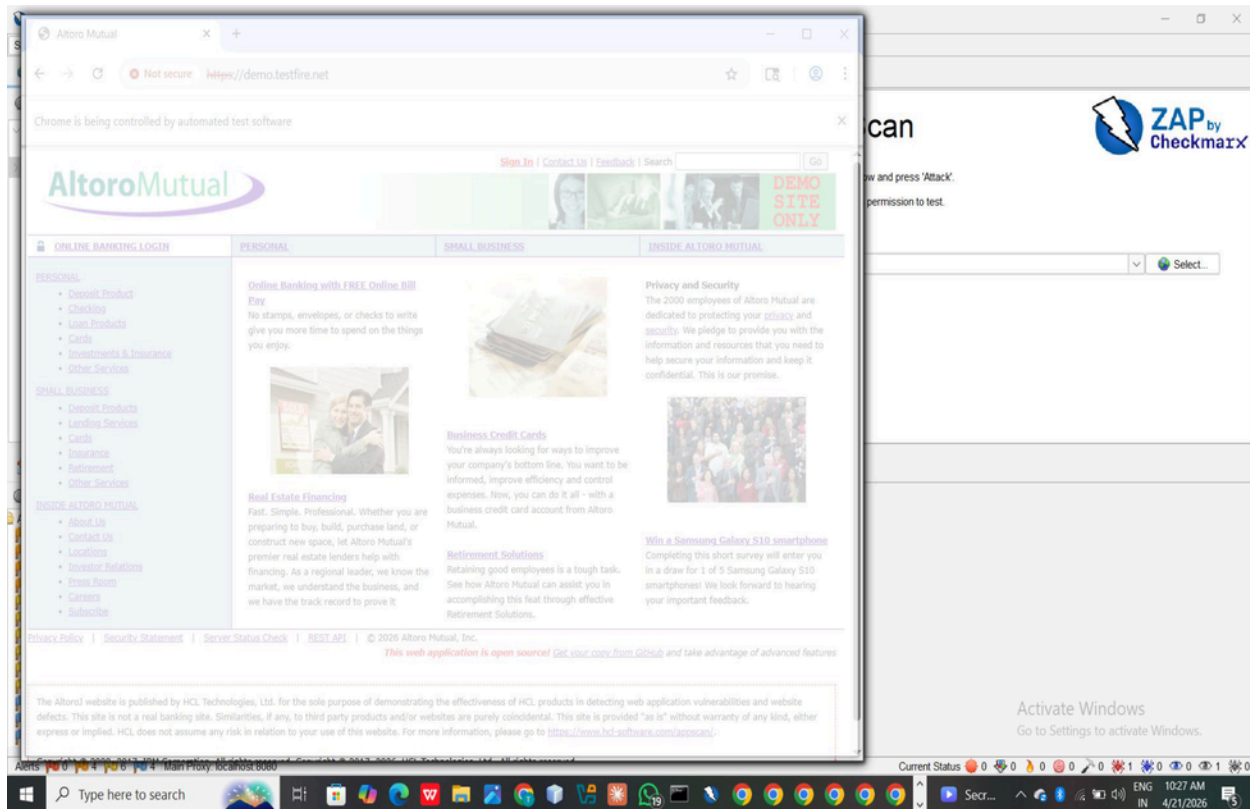
Activate Windows
Go to Settings to activate Windows.

Type here to search

33°C Sunny 10:20 AM 4/21/2026

Screenshot 3: Altoro Mutual Banking Demo Website

Live screenshot of the target application(demo.testfire.net)showingtheintentionally vulnerablebankingwebsite. This is the website that was analyzed for security vulnerabilities. Browser shows 'Not secure' warning.

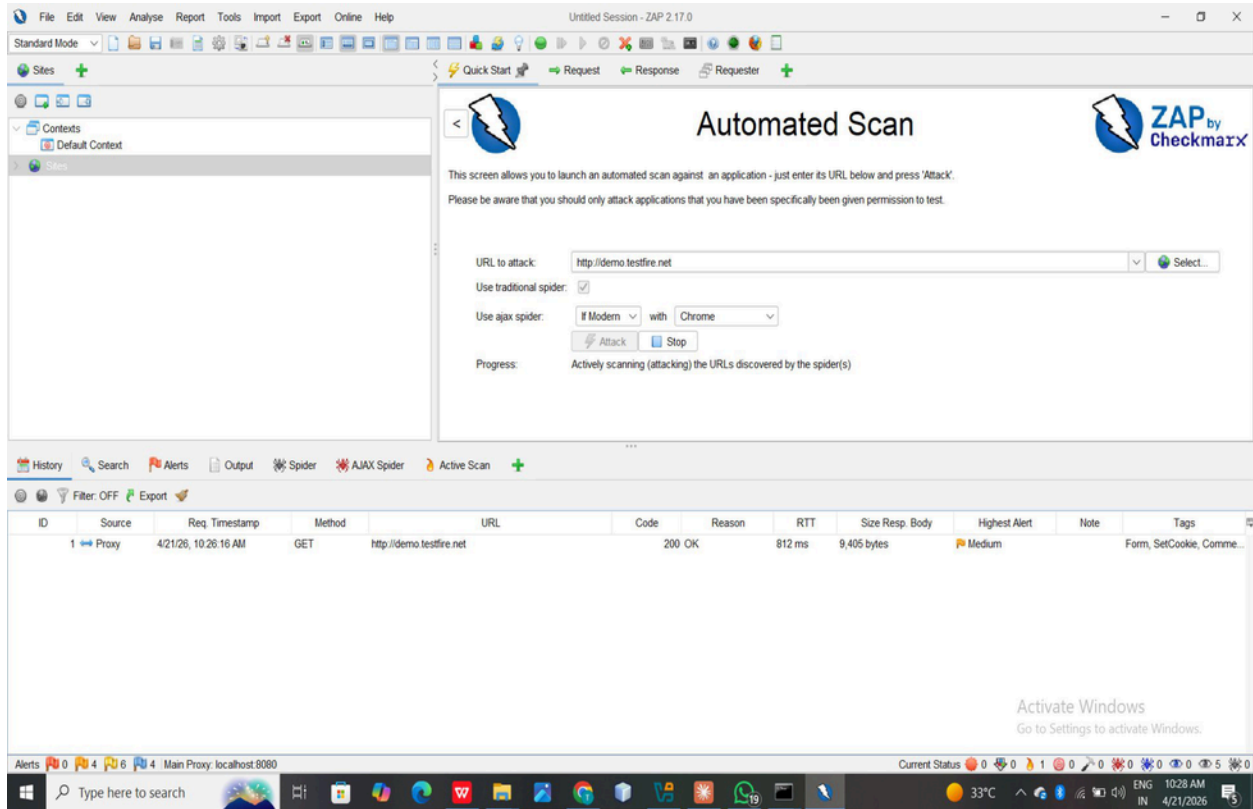


Screenshot 4: Altoro Mutual Application Home Page

Main banking application interfacedisplayingaccountinformation,navigation menus,andfinancialservices. Multiple entry points for potential vulnerability testing visible.

Screenshot 5: OWASP ZAP Automated Scan Interface

OWASP ZAP 2.17.0 tool interface showing the Automated Scan feature. URL field shows the target (http://demo.testfire.net). Scanning options for traditional spider and AJAX spider are visible.



Screenshot 6: ZAP Report - Alert Types Documentation (Part 1)

ZAP HTML report showing detailed alert type information including CWE ID, WASC ID, and security references. Displays information on Anti-CSRF tokens and Content Security Policy (CSP) header vulnerabilities.

Alert Types

This section contains additional information on the types of alerts in the report.

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site-Request-Forgery-Prevention-Cheat-Sheet.html https://cwe.mitre.org/data/definitions/352.html

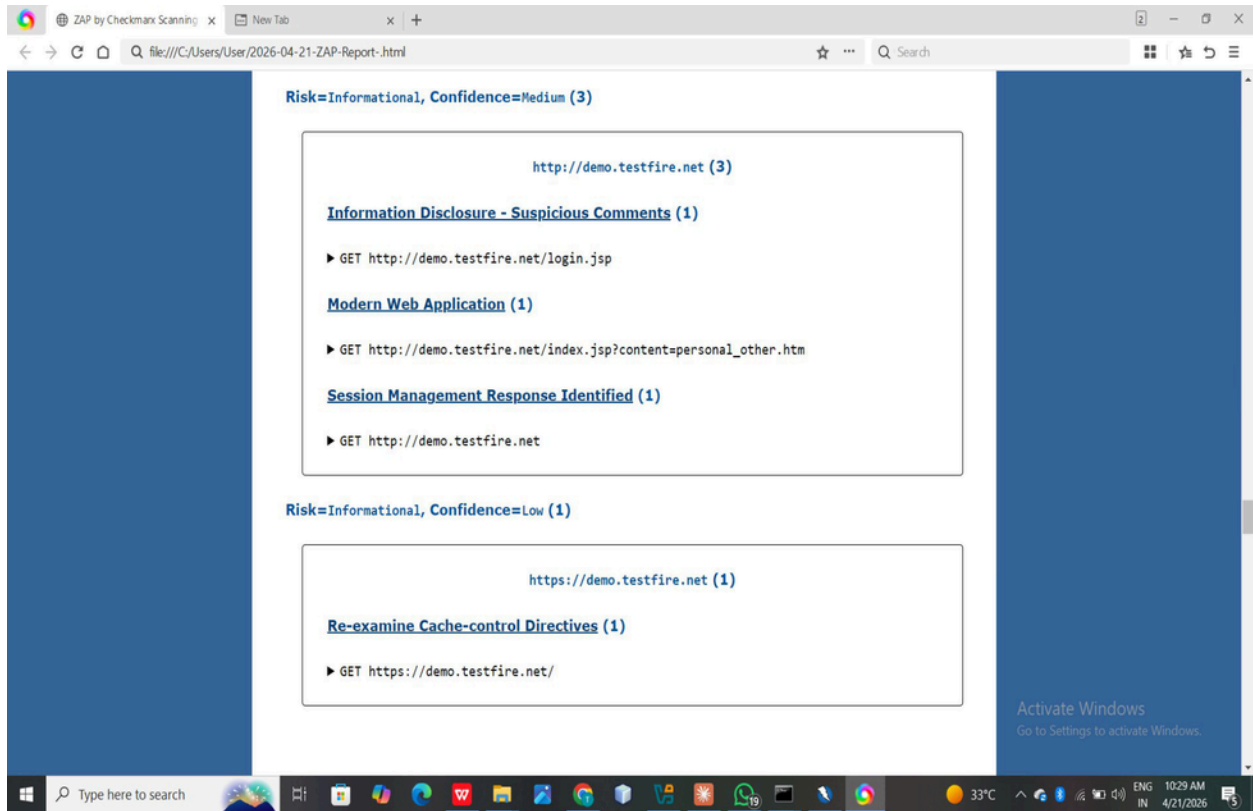
Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP

Activate Windows
Go to Settings to activate Windows.

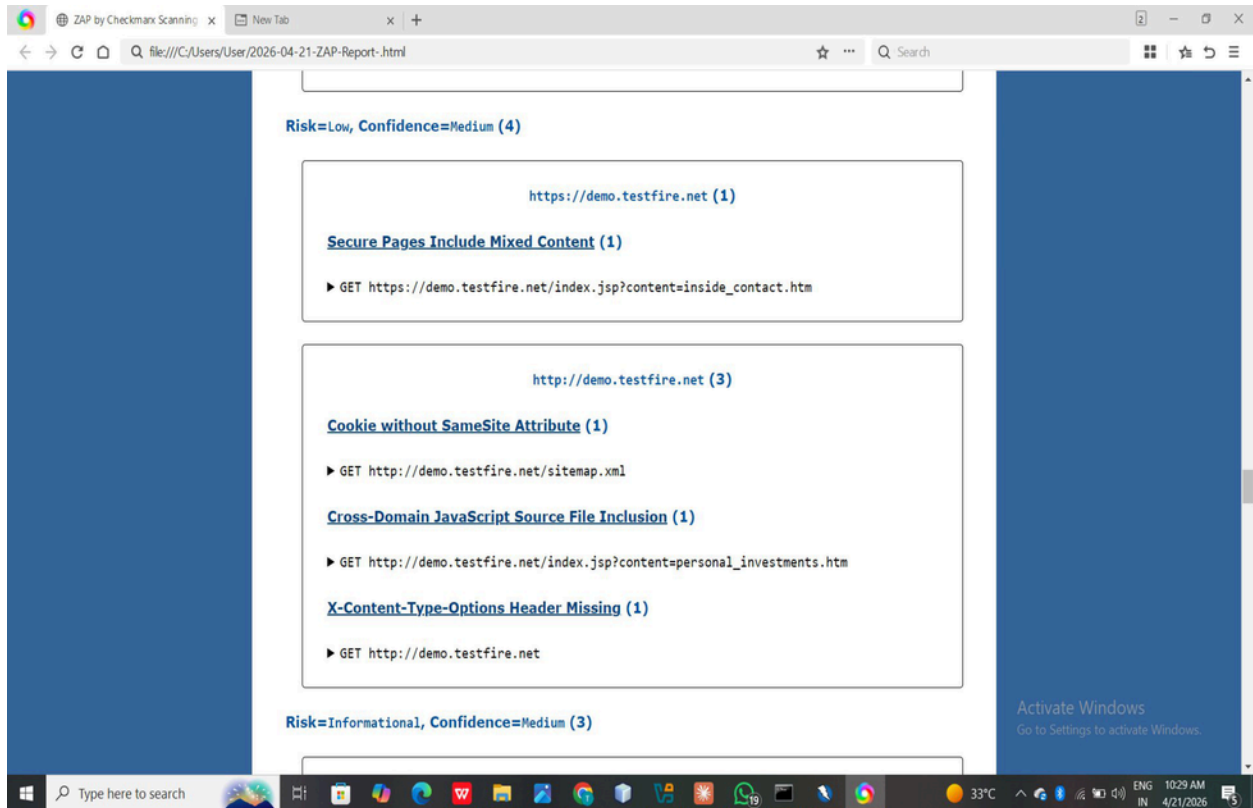
Screenshot 7: ZAP Report - Informational Alerts and Findings

Report excerpt showing informational-level findings from ZAP passive scan including suspicious comments detection, modern web application identification, and session management response analysis.



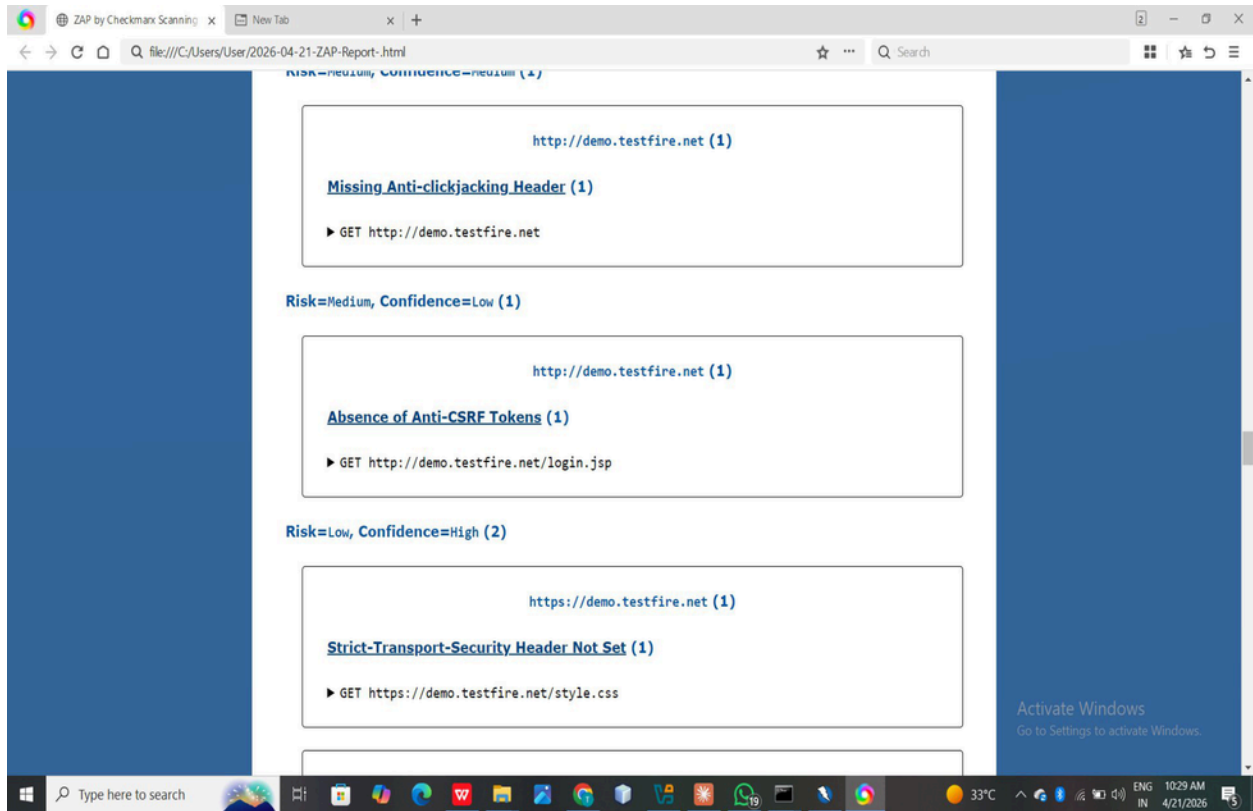
Screenshot 8: ZAP Report - Low and Medium Risk Alerts

Detailed alert listing showing cookie security issues (SameSite), cross-domain JavaScript inclusion, mixed content, X-Content-Type-Options, and missing anti-clickjacking headers.



Screenshot 9: ZAP Report - Medium Risk Alerts (Continued)

Additional medium-risk findings including missing anti-clickjacking header on homepage and absence of Anti-CSRF tokens on login page. Shows specific URLs affected.



Screenshot 10: ZAP Report - Alerts Summary Page

Summary statistics page from ZAP report showing count of alerts by risk level and confidence. Includes insights on network failures, response codes, and endpoint content types.

The screenshot shows a web browser window displaying a ZAP (Zed Attack Proxy) report. The browser's address bar shows the file path: `file:///C:/Users/User/2026-04-21-ZAP-Report-.html`. The report is titled "Alerts" and lists three security issues for the target `http://demo.testfire.net`.

Alert 1: Risk=Medium, Confidence=High (2)

- Content Security Policy (CSP) Header Not Set (1)**
 - ▶ GET `http://demo.testfire.net/sitemap.xml`
- Sub Resource Integrity Attribute Missing (1)**
 - ▶ GET `http://demo.testfire.net/index.jsp?content=personal_investments.htm`

Alert 2: Risk=Medium, Confidence=Medium (1)

- Missing Anti-clickjacking Header (1)**
 - ▶ GET `http://demo.testfire.net`

Alert 3: Risk=Medium, Confidence=Low (1)

The browser's taskbar at the bottom shows the Windows Start button, a search bar, and various application icons. The system tray on the right indicates a temperature of 33°C, the time as 10:29 AM on 4/21/2026, and the language as ENG IN.

Screenshot 11: ZAP Report - Alert Types Reference (Part 2)

Continuation of alert type documentationshowingvulnerabilitydetails, CWEReferences,WASCReferences,andexternal security documentation links for remediation.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	26
Low	Warning		ZAP warnings logged - see the zap.log file for details	53
Info	Informational		Percentage of network failures	11 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 2xx	53 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 3xx	1 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 4xx	44 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/javascript	2 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/pdf	1 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/x-shockwave-flash	1 %

Report Summary

Objective: This Phishing Detection & Awareness Report was created to educate employees about identifying and avoiding phishing attacks through real-world examples and practical guidance.

Methodology: The report includes analysis of three actual phishing email patterns commonly sent to organizations. Security scanning evidence (screenshots) demonstrates professional vulnerability assessment techniques using industry-standard tools (OWASP ZAP, Nmap). All technical analysis uses non-technical language for employee understanding.

Target Audience: All company employees. No technical expertise required.

Classification: For Internal Use Only — Employee Awareness Training

Document Generated: May 02, 2026